
WHITE PAPER · PORTFOLIO & AI GOVERNANCE

Enterprise AI Trust Is Built Through Operating Evidence, Not Tool Novelty

The proof for one approved use does not cover the next

Marco Policani

Enterprise Portfolio · PMO · AI Operating Governance

policani.net · linkedin.com/in/marcpolicani

July 2026

EXECUTIVE SUMMARY

The proof that an AI system can be depended on belongs to one use. A record that travels with the system, says what it covers, and is retested when anything changes lets the next team build on it.

An AI tool approved for one team's use is not approved for the next team's. The second team can depend on the first team's experience for a use nobody tested, or reopen the whole debate. This paper recommends an evidence pack that travels with the system: what it did, on what basis, where it has and has not been tested, and who answers for depending on it. The paper offers the pack as a design, not a proven method.

- 01** Each new use needs its own answers to four questions: what the system did, on what basis, where it was tested, and who answers. The first team's answers only partly carry over.
- 02** Keep the pack in two parts: a record of the system, kept by the person or team that runs it for everyone, and a record of each use with its tests, its owner, and what it does not cover.
- 03** Test again when the model, the inputs, or the use changes, when something goes wrong, or when a set interval passes. A better model counts as a change.

When a second team asks to use the system

Consider an AI assistant that drafts summaries of customer contracts for a sales-operations team. A risk reviewer approved that one use after the team tested it, and the team has used the assistant since. Now the procurement team asks to use the same assistant on supplier contracts. The first approval covers customer contracts for sales operations. It does not cover supplier contracts, and its tests and notes sit in one team's files. This is an illustration, not an account of a real company, and it reports no result.

The procurement lead has two choices, and both are poor. The lead can depend on the first team's good experience for a use nobody tested. Or the lead can reopen the

whole debate, which makes every new use as slow as the first. The first choice risks exposure nobody has measured. The second makes useful systems wait.

This paper's position is that the proof has to be written so it can travel and be checked again. Call that record an evidence pack. It says what the system did, on what basis, where it has and has not been tested, and who answers for depending on it, and it is kept current as the system and its uses change. Here the system is the AI assistant or tool itself, and a use is one task for one group of people with one kind of input.

The records in the pack are what the paper calls operating evidence: what was kept while the system did real work or was tested for it, not how new or impressive the tool looks. Trust means the owner can show those four things for one use, not a feeling about the tool.

The paper starts after the first approval. "The Demo-to-Production Gap" covers that earlier decision, the written approval a business owner signs before a tool goes into real work. In this paper's design, that approval and the tests behind it become the first use's part of the pack. The second use answers the four questions again, plus whichever of that paper's seven production questions (workflow fit, operating ownership, representative cases, exception recovery, observable controls, lifecycle support, and stop authority) the new use changes.

This paper covers what happens to the proof afterward: how it reaches the next team, what has to be tested again when the use changes, and who keeps it current. It is written for the executive or program lead who runs an AI system that one team already uses and another team wants.

Why a capable system can stay parked

A strong pilot can end up on low-stakes work at the edge of the business and never enter the work that would justify the investment. That is this paper's observation, and no source here counts how often it happens. One response is to ask for a better model. This paper reads the stall differently: the people accountable for important work cannot show that they can depend on the system for that work, and a stronger model does not give them that. A new model is a change like any other, so the tests run on the old one may no longer cover it.

This is the paper's reading, not a measured cause. Two surveys fit it without testing it. In McKinsey's survey of about 500 organizations, taken from December 2025 to January 2026, nearly two-thirds of respondents named security and risk concerns as

the top barrier to fully scaling agentic AI, meaning AI that takes actions on its own. That was well ahead of regulatory uncertainty or technical limitations.[1] Deloitte's survey of 3,235 leaders found that only one in five companies has a mature governance model for autonomous AI agents.[2] McKinsey asks what holds leaders back, and Deloitte asks how mature their governance is. Neither measures why a particular pilot stalled.

Two outcomes would show the reading wrong. One is a pilot with a current pack, a named owner, and tests that say what they do not cover, which is still kept out of important work. The other is a pilot that moves into important work on a better model alone, with no new tests behind it. Either would mean something other than proof is missing. Where a parked pilot has no such record, the design below is meant to supply it.

The stakes rise as systems begin to act. McKinsey describes the risk growing from a wrong statement to a wrong action, tool misuse, or work beyond set guardrails.[1] This paper infers that the more a system can do, the stronger the proof the owner needs before the business depends on it.

Four questions, asked again for each use

The owner is the person who answers for one use, such as the procurement lead for supplier contracts. An owner can depend on a system for a use only when able to show four things:

- What did it do: a record of the system's outputs and actions in that use.
- On what basis: the sources, inputs, and reasoning trail behind those outputs.
- Where has it been tested, and where has it not: the cases covered, and the cases that were not.
- Who answers: the named owner who decides whether to depend on the output.

If the owner cannot show all four, the system is not yet ready for that use, even if the demo went well. Because each answer belongs to a use, a second use starts with four new questions, and the first team's answers only partly carry over.

In safety engineering this kind of proof is called an assurance case. The National Institute of Standards and Technology (NIST) report on software assurance describes a structured assurance case as a documented body of evidence that gives a convincing and valid argument that a set of critical claims about a system is justified for a given application in a given environment.[3] The last words matter here,

because the claim belongs to an application and a setting. NIST wrote about software in 2009, not AI. It called the method an active topic of research and said further work was needed on how much evidence is sufficient and on maintaining and revising assurance models.[3] This paper borrows the idea and does not claim it has been shown to work for AI.

Naming an owner has some support, though less than the paper needs. In McKinsey's survey, organizations that assign clear ownership for responsible AI, through AI-specific governance roles or internal audit and ethics teams, averaged 2.6 on its four-level maturity scale. Organizations without a clearly accountable function averaged 1.8.[1] That is an association across companies. It does not show that naming an owner raises trust in a use, and the owner this paper means is one person for one use.

What carries over to a second use, and what is checked again

The four questions are the same for every use, but the answers differ in how far they travel. The history of what the system did stays useful but cannot stand in for a record of the new use. The sources may or may not be the same. The tests cover only the cases that were tested, so a new kind of document, customer, or task needs its own. The first owner also cannot answer for the second use. The supplier documents and the history of what the system did carry over, which saves the new owner from rediscovering them. The tests, any sources that differ, and the answer to who is accountable are the new owner's work.

EXHIBIT 1**What carries over to a second use and what is checked again****What did it do?**

History carries over. The new use needs its own record of outputs.

On what basis?

Check whether sources and inputs match. List any that differ.

Where is it tested?

Tests cover only the first use's cases. Test the new use's own.

Who answers?

The new use gets its own named owner. The first owner cannot answer for it.

The evidence pack: what stays with the system and what stays with the use

Researchers proposed one form of this record before the current wave of AI. In 2018, a group of authors proposed FactSheets, a standard document that the supplier of an AI service would fill in to state its purpose, performance, safety, security, and provenance, which means where it came from and how it was built.[4] They modeled it on supplier declarations used in other industries. The proposal asks for the intended use and the domains the service was tested on, and it asks whether the document is updated each time the service is retrained. It includes example answers for two fictional services, and the FactSheets paper reports no study of whether buyers use such documents. A supplier writes it before it knows a given buyer's use, so this paper infers that the buyer still needs a record of its own.

EXHIBIT 2**The two parts of an evidence pack****System part**

Version, supplier, changes, test results, incidents, weak spots. Kept by the system steward.

Use part

Purpose, cases tested and not tested, review, owner, and a line on what it covers. Kept by the use owner.

The pack has two parts, kept by two different people. This paper's design is the split.

- The system part holds what is true for every use. It states what the system is, which version and supplier, what has changed and when, the supplier's own documents, the incident history, and the known weak spots. It also holds the results of tests run for every use so far, as a library the new owner can read, not as proof for the new use. The system steward keeps it. The steward is the person or team in the company that runs the system for everyone, often the AI program team.
- The use part holds what is true for one use. It states the purpose, the cases tested and the results, the cases not tested, how human review works, which cases go to a person instead of the system, and the named owner. It ends with one line, the covers line, that says what the pack covers, meaning the version tested and the date, and what it does not. The owner of that use keeps it.

The steward also keeps a register of uses: one line for each use, with its owner, the date its pack was last reviewed, and any trigger still open. NIST's profile for generative AI suggests warning systems that show when a system is being used in a new domain where earlier assumptions may no longer hold.[5] A register lists only the uses someone reports, so the steward also checks who requests access or licenses, and a use with no entry has no pack.

A reviewer who did not build the pack reads it against the four questions and tries to find an answer that is missing or untested. The reviewer can come from the risk team, internal audit, or the owner of another use. This paper expects the pack to help a buyer, auditor, or board inspect the case without having attended the pilot. No source here measures how often they ask, so that is an expectation.

The cost is real, and no source prices it. As planning estimates, not measurements: the steward needs about a day to assemble the system part once and about an hour to update it after each vendor change. The owner and a few colleagues need a few days to build a use part, mostly the testing a team would want before depending on the assistant anyway. The reviewer needs about two hours per pack. Replace these with your own numbers after the first one.

Reviewing the second use

In the illustration, the procurement lead becomes the owner of the new use. The lead first checks that the system part is current, meaning the version it describes is the version running. Then the lead writes the use part: the purpose, the cases to test, and

the owner. Supplier contracts differ from customer contracts in length, wording, and who wrote them, so the first team's tests do not cover them. The procurement team runs the assistant on a sample of its own contracts, including the ones the team finds awkward, and records what it finds. The reviewer reads the result.

The rule is the one "The Demo-to-Production Gap" sets for a first approval, applied to the new use. If all four answers are in place, the owner of the new use decides whether to go ahead and which of the seven production questions the new use changes, and the reviewer checks that judgment and can hold the decision until an answer is supplied. If an answer is missing, because no tests exist yet for a kind of contract, the new use waits. If an answer is weak, because the tests cover only a few contract types, the new use is limited to the types covered. The first team's use continues unless the review of the shared system part finds a problem.

This paper expects the second review to look at the differences instead of the whole system. No study here measures that saving, so it remains an expectation.

Keeping the evidence current

A pack filed once is only a snapshot. Models change, inputs change, and use can drift beyond what was tested. NIST's AI Risk Management Framework describes risk management as continuous and iterative across the system's life, and its profile for generative AI suggests defining who is responsible for periodic review and re-evaluating risk when a model is adapted to a new domain.[5][6] This paper turns that into five triggers. They are the paper's design, and the interval is a planning assumption:

- The system changes: a new model version, a vendor update, or new settings.
- The inputs change: a new data source or a new kind of document.
- The use widens: a new group of users or a new task.
- Something goes wrong: an error that a user catches, or an incident.
- Time passes with none of the above: a short check at a fixed interval, for example every six months for a high-consequence use.

When a trigger fires, the steward tells the owners of every use the change touches. Each owner decides whether to retest and which cases to retest, and notes the date. The owner judges how big the change is, so a second person has to check that judgment: when a change is called small, the reviewer samples those calls. A better

model, then, is a trigger like the rest. The steward records the new version and the owners retest the cases the old tests covered.

A trigger with no retest behind it counts as a missing answer for whatever the change touches. The owner holds that part of the use, or limits the use to cases the change does not touch, and the register shows the open trigger. The reviewer reads the register for open triggers each time a pack is reviewed, and the program sponsor, who appointed the steward and the reviewer, enforces any hold the reviewer asks for. A pack that has passed its triggers without a review does not support a current claim. The covers line shows it, because it states the version and the date the tests were run.

How an evidence pack fails

An evidence pack can fail in four ways. These are the paper's names for them, drawn from its reading of the pack and not from a counted list. The first two are failures of the four answers, the third is a failure of the triggers, and the fourth is a failure of the covers line.

EXHIBIT 3

Four ways an evidence pack stops being evidence

Evidence theater

Pages that count activity but do not answer the four trust questions.

False precision

Numbers that imply more testing than the team performed.

Approval-only pack

A pack built to clear an approval but not kept current as the system changes.

Borrowed pack

A pack written for one use, handed to a second team as if it covered the new one.

The first is evidence theater. Teams fill the pack with usage dashboards and demo decks that count activity but do not prove reliable results. Usage shows that people tried the tool. It does not show that the tool did the right thing, for the right reason, inside the cases that were tested, under a named owner.

The second is false precision. A performance number can imply more testing than the team did. A number without its test circumstances hides the gap it should reveal. A section on what was not tested that offers comfort but names no case hides it too.

The third is the approval-only pack. The team builds it to clear an approval step and never updates it. Its evidence may have been true at launch, but the system keeps changing, and without an owner to maintain it the pack becomes a history file.

The fourth is the borrowed pack. A pack written for one use is handed to a second team as if it covered the new one. Every page may be accurate and the pack still answers the wrong use.

Objections and limits

It will become paperwork. It will if no one has to use it. The test is whether a decision in the last quarter relied on a pack, and whether the reviewer found a gap in one. A pack that no one opens before a decision is a filing. Keep each page to what answers one of the four questions, and cut the rest.

It sounds like a certification. It is not one. No single standard governs AI evidence packs; FactSheets and NIST's documents are voluntary, and each company designs its own record. A complete pack can still sit beside a system used beyond what was tested. The pack gives the owner something to judge, and the judgment stays with the owner.

We are a small team with one use. Then write one page, with the four answers, the covers line, and the triggers. Split it into system and use parts when a second use appears or is likely. The page still goes stale on its own, so the triggers still apply.

Testing again after every change will slow us down. The owner may judge a change to be small and record why. The reviewer samples those calls, as above. Without a retest, the first sign that a changed system no longer does what the tests showed may come from a user.

The evidence is thin. No study here tests whether packs shorten the review of a second use or reduce incidents, and NIST describes assurance cases for software as still being researched. The four questions, the two parts, the register, and the five triggers are this paper's design. The reading of why pilots stall is unmeasured, and the paper names what would show it wrong.

What to do next

Pick the system that already has one approved use and is most likely to get a second, or already has a team asking. The executive who sponsors the AI program appoints a steward and a reviewer from outside the team and funds their time from the program's budget. The steward assembles the system part and starts the register of uses. The owner of the first use writes the use part from the written approval and the tests behind it, and ends it with the covers line. The steward writes down the five triggers and the interval the sponsor chooses. When the next team asks, hand over the pack and ask that team's owner to answer the four questions for the new use. If the system has no approval for its first use yet, begin with "The Demo-to-Production Gap."

In the illustration, the procurement lead no longer has to choose between depending on an untested use and starting over. The pack says what the assistant did, on what basis, where it was tested, and who answers, and it says plainly that supplier contracts are not yet covered. The lead's review is the work of covering them.

Notes and sources

[1] Gabriel Morgan Asaftei, Roger Roberts, Abby Sticha, and Cécile Prinsen, "State of AI trust in 2026: Shifting to the agentic era," McKinsey & Company, March 25, 2026.

<https://www.mckinsey.com/capabilities/tech-and-ai/our-insights/tech-forward/state-of-ai-trust-in-2026-shifting-to-the-agentic-era>

[2] Deloitte, "The State of AI in the Enterprise," 2026 AI report, Deloitte AI Institute.

<https://www.deloitte.com/us/en/what-we-do/capabilities/applied-artificial-intelligence/content/state-of-ai-in-the-enterprise.html>

[3] Thomas Rhodes, Frederick Boland, Elizabeth Fong, and Michael Kass, "Software Assurance Using Structured Assurance Case Models," NIST Interagency Report 7608, National Institute of Standards and Technology, May 2009.

<https://nvlpubs.nist.gov/nistpubs/Legacy/IR/nistir7608.pdf>

[4] Matthew Arnold, Rachel K. E. Bellamy, Michael Hind, Stephanie Houde, Sameep Mehta, Aleksandra Mojsilović, Ravi Nair, Karthikeyan Natesan Ramamurthy, Darrell Reimer, Alexandra Olteanu, David Piorkowski, Jason Tsay, and Kush R. Varshney, "FactSheets: Increasing Trust in AI Services through Supplier's Declarations of Conformity," arXiv:1808.07261, 2018; revised 2019. <https://arxiv.org/abs/1808.07261>

[5] Chloe Autio, Reva Schwartz, Jesse Dunietz, Shomik Jain, Martin Stanley, Elham Tabassi, Patrick Hall, and Kamie Roberts, "Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile," NIST AI 600-1, July 26, 2024. <https://doi.org/10.6028/NIST.AI.600-1>

[6] National Institute of Standards and Technology, "AI Risk Management Framework Core," AI RMF 1.0, 2023. <https://airc.nist.gov/airmf-resources/airmf/5-sec-core/>

About the author

Marco Policani is an enterprise portfolio, PMO, and AI operating-governance leader. He builds portfolio governance systems where AI carries the analytical load and named humans own every decision — an approach documented across case studies, walkthroughs, and working governance guides on his portfolio site.

Portfolio & governance library: policani.net/governance · Full portfolio: policani.net · LinkedIn: linkedin.com/in/marcpolicani

This white paper may be shared freely with attribution. © 2026 Marco Policani.